ReTrust

Cyber-risk evidence before the purchase order

What the tool does, how it works, measured benchmarks, and where it fits alongside other security tools.

The decision it supports

A procurement team has a shortlist of industrial controllers, switches or other OT products. ReTrust collects the public security evidence for each named candidate and turns it into a traceable review: PREFER, CONDITIONAL, AVOID or NOT ASSESSED.

Why it is useful

A requisition often arrives with a manufacturer, model, order number and proposed firmware, before there is a device to inspect. Reviewing advisories, exploitation signals, fixes and supplier restrictions separately makes it hard to compare candidates consistently.

ReTrust brings that work into one local workflow. It helps buyers find disqualifying evidence early, ask the supplier specific questions, and preserve the rationale with the procurement record.

PUBLIC EVIDENCE	MEASURED CORPUS	LOCAL WORKFLOW
3,937 CSAF advisories	28,951 product entries 12,061 distinct CVEs	CLI, interactive menu and browser workspace

Audience: OT security engineers, procurement teams, integrators and security reviewers. OT means operational technology, including equipment used to control or monitor physical processes.

Scope: public-evidence decision support. Scores are not probabilities of compromise, a certification, or a replacement for engineering acceptance tests.

From a part number to evidence

STAGE	WHAT RETRUST DOES
1. Collect	Fetch CSAF advisories, CISA KEV, FIRST EPSS and optional screening/certification sources. Preserve local provenance. [1, 2, 3]
2. Index	Parse product trees, relationships, version ranges and product-specific remediation into SQLite. Stage rebuilds before replacing the active index.
3. Resolve	Try manufacturer order number, then normalized vendor/name matching and a token-subset fallback. Reject conflicts and ambiguous requests.
4. Filter	Use the supplied firmware to narrow affected ranges. Keep undecided ranges visible and in scope.
5. Assess	Apply hard gates and calculate weighted evidence pillars. Show missing evidence separately from a good score.
6. Review and export	Compare candidates, inspect evidence, prepare supplier questions, and retain HTML, JSON, CSV or VEX output as appropriate.

Why manufacturer order numbers matter

In this local CISA OT corpus, only 60 of 28,951 product entries carry a CPE identifier (0.21%). Declared order numbers appear on 8,211 entries (28.36%); including recovered numbers raises coverage to 9,575 entries (33.07%).

That is about 137 times as many entries with declared order numbers as with CPE. It supports ReTrust's choice of input identifier for this dataset. It does not measure a scanner's total identifier coverage or its performance on industrial networks.

An advisory product entry is not a unique device

The same product can appear in multiple advisories. Corpus totals describe records, not installed assets or unique hardware models.

How to read a verdict

Higher scores indicate more favorable evidence under the configured weights. The default composite is a weighted product of four pillars (exposure, patch availability, vendor practice, certification); evidence quality is reported separately and never scored.

PILLAR	WEIGHT	EVIDENCE USED
Exploitation	30%	KEV, ransomware flags and peak EPSS
Severity	20%	CVSS severity and exploitability characteristics
Patch availability	20%	Vendor fix, mitigation/workaround, unavailable or unknown remedy
Vendor practice	15%	Advisory completeness and published security-advisory practice
Certification	15%	Available certification evidence and product scope

```
Composite = sum(pillar score x weight) / sum(weights)
```

DEFAULT BAND	READING
PREFER: 70-100	More favorable evidence; still review scope and suitability.
CONDITIONAL: 40-<70	Review mitigations, supplier commitments and evidence gaps.
AVOID: <40, or a gate	A numeric band or a disqualifying gate triggers this result.
NOT ASSESSED	The request did not resolve reliably; no numeric score is given.

Gates override a score

Known exploitation, ransomware linkage, a critical likely-exploited flaw without a remedy, or configured supplier-screening evidence can force AVOID. Screening can block an unresolved product when vendor evidence is sufficient. [1]

EPSS estimates exploitation of a CVE in the next 30 days. It is not the probability that this particular device or facility will be compromised. [3]

Version-match confidence values are rule-based heuristics, not calibrated probabilities. Repeated CVEs are counted once for exploitation gates; pillar proportions may use distinct advisory findings, which are labeled.

Benchmarks you can reproduce

MEASUREMENT	RESULT	WHAT IT ESTABLISHES
Version-range coverage	27,193 / 28,651 **94.91%**	The parser can decide these range forms. It does not independently establish correct affectedness for every firmware.
Coverage of eligible ranges	27,193 / 28,092 **96.80%**	Excludes 559 ranges classified as serial-, revision- or date-dependent. Another 899 ranges remain missed.
Round-trip precision	3,988 / 3,994 answered **99.85%**	Returned matches include the originating advisory. Six answered queries did not; six more abstained.
Round-trip recall	3,988 / 4,000 attempted **99.70%**	The source advisory was recovered in the sampled query. Extra incorrect matches are not separately penalized.
Hand-written buyer queries	20 / 21 **95.24%**	A small authored set including shorthand, typos, conflicts and abstention cases. Not an independent test set.

How the round-trip test is constructed

Products are selected deterministically from the same advisory corpus used by the resolver. Query generation removes parenthetical text and punctuation, lowers case and keeps the first four words. The original order number is also supplied when present. Success means the originating advisory appears among the returned matches.

By method: order number 1,334/1,334; normalized name 2,617/2,623; token subset 37/37. These are sample results, not universal accuracy guarantees. The buyer-query miss is “Belden RS switches”: the matcher abstains instead of making a broad vendor-substring guess.

Use the precise claim

ReTrust shows high source-advisory recovery on its internal corpus-based benchmark. Independent product/version labeling and returned-match precision are still needed before claiming general matching accuracy.

Speed and predictive limits

Local command latency

CASE	MEDIAN	P95
Search S7-1500	158.9 ms	182.9 ms
Assess ABB AC 800M	504.6 ms	542.5 ms
Assess Siemens by order number	507.8 ms	530.2 ms
Compare two candidates (300 samples)	544.7 ms	570.7 ms

20 serial fresh CLI processes per case after one warm-up; warm OS cache; stdout discarded. Wall-clock time includes Python startup. P95 uses the nearest-rank method. These are measurements on a shared development machine, not a load or cross-tool benchmark.

Environment: Python 3.13.9; AMD Ryzen 5 5500U with Radeon Graphics; 12 logical CPUs reported. Database: 41.0 MiB. Full environment details and raw summaries are in docs/benchmarks/latency.json.

Does a higher score predict fewer later vulnerabilities?

The current backtest does not establish that. At a 2022-01-01 cutoff, 5,848 products are scored on pre-cutoff advisories and compared with later CVE disclosure. The diagnostic uses 1,000 seeded permutations.

COMPARISON	SPEARMAN RHO
Score vs later CVE count, pooled	+0.456
Within vendor, 3,822 products	+0.258
Within vendor, excluding Siemens	+0.045

The positive association weakens when vendor effects are controlled. This is consistent with disclosure and research-exposure effects; it does not prove a causal explanation. Only two products across two vendors qualify for the later-KEV outcome, too few for an exploitation-rate claim.

A defensible boundary

Use the score to organize current evidence and questions. This backtest does not validate the score as a predictor of real-world compromise.

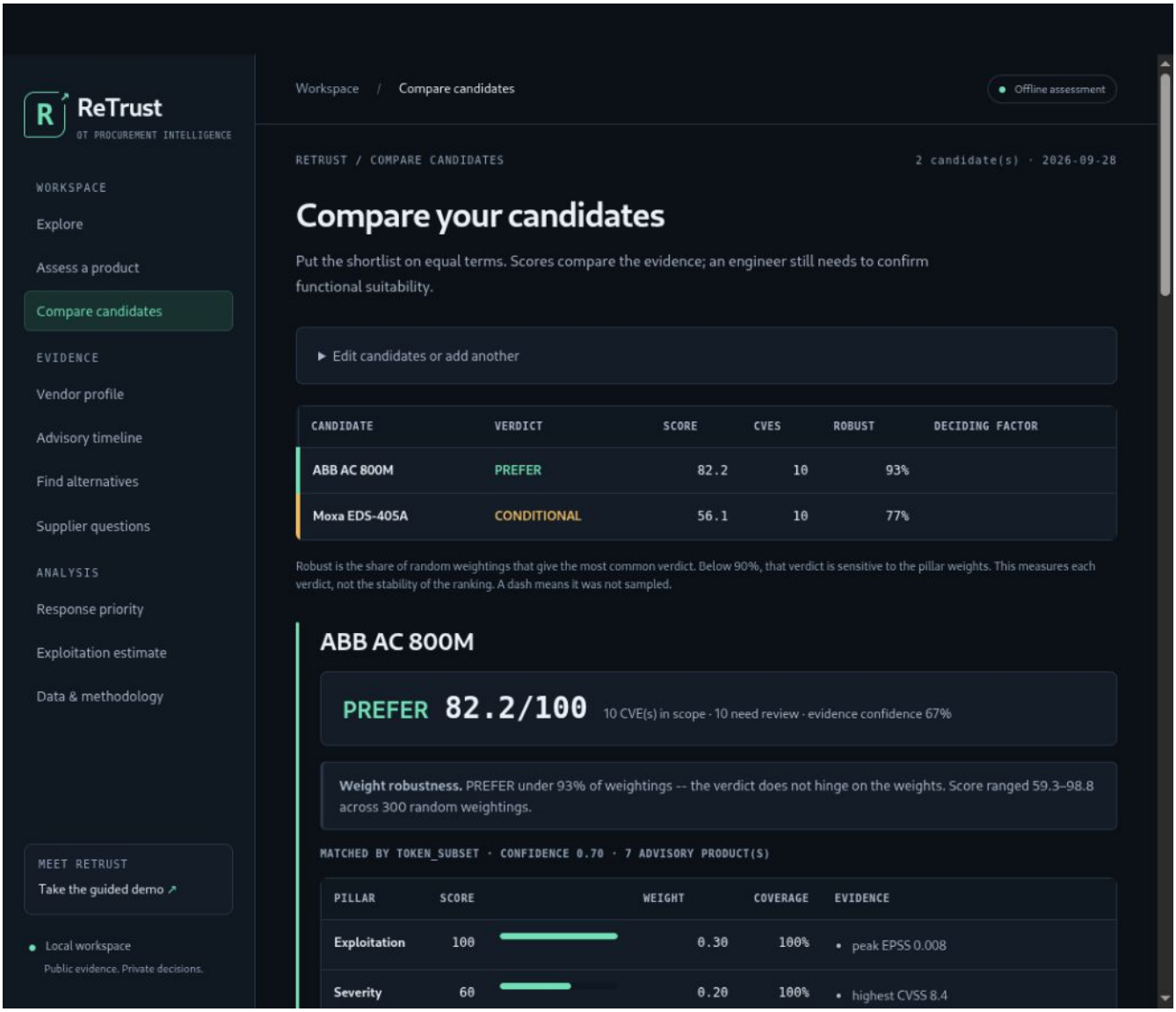
How it compares with other tools

These tools answer related but different questions. The descriptions below come from their official documentation. No competing tool was run in a common experimental test. Availability and features may change.

TOOL	PRIMARY JOB / INPUT	RELATIONSHIP TO RETRUST
ReTrust	Named OT candidate, order number and firmware; public advisory evidence.	Compare a procurement shortlist and export its evidence before deployment. No live network discovery or binary analysis.
Nessus [4]	Vulnerability assessment, missing patches, configuration/compliance checks on systems.	Use for assessing deployed systems. ReTrust's advisory-based shortlist is a different input and decision workflow.
Nozomi Guardian [5]	Passive OT/IoT traffic observation, asset inventory, vulnerabilities and anomaly/threat detection.	Use for operational network visibility. ReTrust does not observe traffic or detect live incidents.
runZero [6]	Asset discovery and exposure management using scanning, passive inputs and integrations.	Use to understand what is present and exposed. Inventory can inform a later named-product review.
Trivy [7]	Vulnerabilities, misconfigurations, secrets and SBOM workflows for software artifacts.	Use for package, image and repository evidence. ReTrust reads a candidate/SBOM list but does not perform equivalent software inspection.
FACT [8]	Firmware unpacking, analysis, searching and comparison from firmware samples.	Use when firmware contents are available. ReTrust does not discover new weaknesses inside binaries.
BloodHound [9]	Graph analysis of identity relationships and attack paths, including AD/Entra and OpenGraph extensions.	Use for attack-path analysis. ReTrust evaluates procurement evidence; it does not collect identity graphs.

ReTrust's practical distinction is its order-number-led procurement workflow, local operation, explicit abstention and exported rationale. This is a description of its focus, not a claim that no other product offers procurement features.

A review someone can follow



Actual local browser capture: ABB AC 800M and Moxa EDS-405A, with no firmware supplied. Source data and weights determine these results.

1. Start with the requisition. Enter an order number or vendor/model and, where known, firmware. Verify that the resolved product is the intended variant.

2. Read the deciding evidence. A current comparison gives Moxa EDS-405A 87.6 (PREFER) and ABB AC 800M 78.0 (PREFER). Without firmware, uncertain ranges remain in scope.

3. Challenge the result. The web samples 300 weightings: 93% and 77% support the respective most common verdicts in this example. The latter merits a closer discussion of priorities.

4. Preserve and act. Export the assessment, use supplier questions to request exact fixed versions and support commitments, and re-score the saved query when evidence changes.

Operate, reproduce and improve

Start locally

```
python3 -m retrust.cli setup
python3 -m retrust.cli shell
python3 -m retrust.cli serve
```

Setup needs network access to obtain sources. Once populated, assessments run locally. The browser workspace defaults to 127.0.0.1:8765. The core package requires Python 3.10+ and no third-party Python runtime packages; some setup, signature and screenshot commands use external tools.

Reproduce the measurements

```
python3 -m retrust.cli eval --sample 4000 --json eval.json
python3 -m retrust.cli backtest --permutations 1000
python3 -m pytest -q
bash smoke.sh
```

Local verification: 831 automated tests passed; 94 real-data smoke checks passed. These cover command workflows, HTTP routes, parsing, output and regression cases, including guards against injection, SSRF and decompression-bomb inputs. They do not constitute an independent security audit.

Know the remaining gaps

Evidence coverage: absent advisories, missing certification or uncertain ranges are not proof of safety. Family-level queries can collect several variants; prefer precise identifiers.

Scoring: weights and gates encode a review policy. Certification may be vendor-level, screening requires scope confirmation, and raw disclosure volume is not a risk ground truth.

Operations: the local web UI has no multi-user authentication or enterprise case-management workflow, but it is read-only and answers GET requests only, exposing none of the commands that fetch data or change the index. Preserve provenance and snapshots, confirm advisory origin with verify (--strict in a pipeline), review source freshness with doctor, and recheck supplier evidence before a decision.

Next validation: build an independently labeled product/version set, measure extra matches and abstention quality, record buyer usability results, and evaluate outcomes across vendors and time.

Reproducibility record

Data captured locally on 28 September 2026. SQLite SHA-256:

`7c1e38886df7fc4ce06fed9f889bc8304c4030c2d6d597eb947050252d1189ed`

Benchmark JSON/text and this PDF builder are retained in the repository.

Sources and evidence record

[1] CISA Known Exploited Vulnerabilities
https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[2] CISA CSAF advisory repository
https://github.com/cisagov/CSAF

[3] FIRST Exploit Prediction Scoring System
https://www.first.org/epss/

[4] Tenable Nessus product capabilities
https://www.tenable.com/products/nessus

[5] Nozomi Guardian capabilities
https://www.nozominetworks.com/platform/guardian

[6] runZero exposure management documentation
https://help.runzero.com/docs/exposure-management/

[7] Aqua Trivy official repository
https://github.com/aquasecurity/trivy

[8] FACT official repository
https://github.com/fkie-cad/FACT_core

[9] SpecterOps introduction to BloodHound
https://bloodhound.specterops.io/get-started/introduction

Evidence retained with the project

```
docs/benchmarks/evaluation.json and evaluation.txt
docs/benchmarks/backtest.json and backtest.txt
docs/benchmarks/latency.json
docs/benchmark-report.md
docs/tool-comparison.md
docs/qa-review.md
tools/build_overview.py
```

Comparison sources [3-9] were read on 28 September 2026. CISA data claims come from the locally indexed corpus and provenance; the public KEV page was not retrievable during report preparation. Product descriptions are summaries, not endorsements or exhaustive feature inventories.

The benchmark cohort is derived from this tool's indexed public corpus. Source publication dates and local capture dates differ. The historical feasibility plan is kept as an explicitly labeled archive.